

Weird proxies/2 and a bit of magic

Weird proxies/2 and a bit of magic - @speakerdeck, GreenDog, Speaker Deck.

- Published: 2021-09-01
- Original: <<https://speakerdeck.com/greendog/2-and-a-bit-of-magic>>
- Preserved from: <https://speakerdeck.com/greendog/2-and-a-bit-of-magic> (live) on 2026-08-06
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Weird proxies/2 and a bit of magic - Speaker Deck

Weird proxies/2 and a bit of magic

<https://zeronights.ru/en/reports-en/weird-proxies-2-and-a-bit-of-magic/>

Reverse proxies and their variations are used everywhere in modern web applications for routing, caching, and access differentiation. This talk is dedicated to new research results about different reverse proxies and new possibilities brought by HTTP/2. It is a collection of tricks for exploiting various misconfigurations.

Results - https://github.com/GrrrDog/weird_proxies

[[image: Avatar for GreenDog](#)]

GreenDog

September 01, 2021

More Decks by GreenDog

[See All by GreenDog](#)

[

How to break SAML if I have paws?

](<https://speakerdeck.com/greendog/how-to-break-saml-if-i-have-paws>)

[[[image: Avatar for GreenDog](#)] greendog](<https://speakerdeck.com/greendog>)

3k

[

Reverse proxies & Inconsistency

](https://speakerdeck.com/greendog/reverse-proxies-and-inconsistency)

[[\[image: Avatar for GreenDog\]](#) greendog](https://speakerdeck.com/greendog)

3

5.9k

[

MITM Attacks on HTTPS: Another Perspective

](https://speakerdeck.com/greendog/mitm-attacks-on-https-another-perspective)

[[\[image: Avatar for GreenDog\]](#) greendog](https://speakerdeck.com/greendog)

2

890

[

Deserialization vulnerabilities

](https://speakerdeck.com/greendog/deserialization-vulnerabilities)

[[\[image: Avatar for GreenDog\]](#) greendog](https://speakerdeck.com/greendog)

1

1.1k

Other Decks in Programming

[See All in Programming](#)

[

<title><a id="</title>君はこのHTMLをパースできるか"></title> #雑LT_study

](https://speakerdeck.com/pizzacat83/can-you-parse-this-html)

[[\[image: Avatar for pizzacat83\]](#) pizzacat83](https://speakerdeck.com/pizzacat83)

0

130

[

Terraform標準の組織で AWS CDKをどう使うか

](https://speakerdeck.com/mu7889yoon/how-to-use-aws-cdk-in-an-organization-that-has-standardized-on-terraform)

[[\[image: Avatar for mu7889yoon / Yuta Nakamura\]](#) mu7889yoon]

(https://speakerdeck.com/mu7889yoon)

1

460

[

【やさしく解説 設計編・中級 #4】 ルールの寿命と、システムの年輪

](https://speakerdeck.com/panda728/yasasiku-sekkei-2-number-4)

[[\[image: Avatar for HideyukiKitao\]](#) panda728](https://speakerdeck.com/panda728)

PRO

2

180

[

React本体のコードリーディング

](https://speakerdeck.com/high_g_engineer/reactben-ti-nokotoriteinku)

[[\[image: Avatar for high-g\]](#) high_g_engineer](https://speakerdeck.com/high_g_engineer)

1

130

[

Augmenting AI with the Power of Jakarta EE

](https://speakerdeck.com/ivargrimstad/augmenting-ai-with-the-power-of-jakarta-ee-8664ddb0-c49d-49b6-bb69-c20ffcccd8ad)

[[\[image: Avatar for ivargrimstad\]](#) ivargrimstad](https://speakerdeck.com/ivargrimstad)

0

440

[

変わらないものが、変わるものを決める — 意図駆動開発 × イベントソーシング × イミュータブル |
What Doesn't Change Decides What Can — IDD × Event Sourcing × Immutability

](https://speakerdeck.com/tomohisa/what-doesnt-change-decides-what-can-idd-x-event-sourcing-x-immutability)

[[\[image: Avatar for Tomohisa Takaoka\]](#) tomohisa](https://speakerdeck.com/tomohisa)

0

1.1k

[

freee が目指す データ マネジメント戦略 AI-Ready 時代を支える 攻めのガバナンスとは

](https://speakerdeck.com/freee/freee-gamu-zhi-su-deta-manezimentozhan-lue-ai-ready-shi-dai-wozhi-eru-gong-menogabanansutoha)

[[\[image: Avatar for freee\]](#) freee](<https://speakerdeck.com/freee>)

PRO

0

180

[

ソフトウェア設計に溶けるインフラ — AWS CDK のインフラ認識論

](<https://speakerdeck.com/konokenj/epistemology-of-cdk>)

[[\[image: Avatar for Kenji Kono\]](#) konokenj](<https://speakerdeck.com/konokenj>)

3

740

[

使いながら育てる Claude Code — 開発フローの1コマンド化 × 繰り返し指摘の自動仕組み化

](https://speakerdeck.com/shiki_kakaku/shi-inagarayu-teru-claude-code-kai-fa-hurono1komandohua-x-zao-rifan-sizhi-zhai-nozi-dong-shi-zu-mihua)

[[\[image: Avatar for endo shiki\]](#) shiki_kakaku](https://speakerdeck.com/shiki_kakaku)

0

1.6k

[

What's New in Android 2026

](<https://speakerdeck.com/veronikapj/whats-new-in-android-2026>)

[[\[image: Avatar for Veronikapj\]](#) veronikapj](<https://speakerdeck.com/veronikapj>)

0

250

[

Google Apps Script で Ruby を動かす

](<https://speakerdeck.com/kawahara/google-apps-script-de-ruby-wodong-kasu>)

[[\[image: Avatar for Shogo Kawahara\]](#) kawahara](<https://speakerdeck.com/kawahara>)

0

130

[

なぜ関数型プログラミングで「型」と「証明」が語られるのか #fp_matsuri

](<https://speakerdeck.com/kajitack/fpmatsumi-functional-programming-types-proofs-connection>)

[[\[image: Avatar for Takuma Kajikawa\]](#) kajitack](<https://speakerdeck.com/kajitack>)

3

1.1k

Featured

[See All Featured](#)

- [
[SF Ruby Conf 2025] Rails X
](https://speakerdeck.com/palkan/sf-ruby-conf-2025-rails-x)
[[\[image: Avatar for Vladimir Dementyev\]](#) palkan](https://speakerdeck.com/palkan)
2
1.2k
[
Money Talks: Using Revenue to Get Sh*t Done
](https://speakerdeck.com/nikkiahalliwel/money-talks-using-revenue-to-get-sh-star-t-done)
[[\[image: Avatar for Nikki Halliwell\]](#) nikkiahalliwel](https://speakerdeck.com/nikkiahalliwel)
0
450
[
We Are The Robots
](https://speakerdeck.com/honzajavorek/we-are-the-robots)
[[\[image: Avatar for Honza Javorek\]](#) honzajavorek](https://speakerdeck.com/honzajavorek)
0
290
[
Lightning talk: Run Django tests with GitHub Actions
](https://speakerdeck.com/sabderemane/lightning-talk-run-django-tests-with-github-actions)
[[\[image: Avatar for Sarah Abderemane\]](#) sabderemane](https://speakerdeck.com/sabderemane)
0
230
[
Tips & Tricks on How to Get Your First Job In Tech
](https://speakerdeck.com/honzajavorek/tips-and-tricks-on-how-to-get-your-first-job-in-tech)
[[\[image: Avatar for Honza Javorek\]](#) honzajavorek](https://speakerdeck.com/honzajavorek)
1

660

[

Ten Tips & Tricks for a 🌱 transition

](https://speakerdeck.com/stuffmc/ten-tips-and-tricks-for-a-transition)

[[\[image: Avatar for Manu Carrasco Molina\]](#) stuffmc](https://speakerdeck.com/stuffmc)

0

160

[

CSS Pre-Processors: Stylus, Less & Sass

](https://speakerdeck.com/bermonpainter/css-pre-processors-stylus-less-and-sass)

[[\[image: Avatar for Bermon Painter\]](#) bermonpainter](https://speakerdeck.com/bermonpainter)

360

30k

[

How to optimise 3,500 product descriptions for ecommerce in one day using ChatGPT

](https://speakerdeck.com/katarinadahlin/brightonseo-2024)

[[\[image: Avatar for Katarina Dahlin\]](#) katarinadahlin](https://speakerdeck.com/katarinadahlin)

PRO

2

3.7k

[

StorybookのUI Testing Handbookを読んだ

](https://speakerdeck.com/zakiyama/ui-testing-handbook-by-storybook)

[[\[image: Avatar for Shingo Yamazaki\]](#) zakiyama](https://speakerdeck.com/zakiyama)

31

6.9k

[

Git: the NoSQL Database

](https://speakerdeck.com/bkeepers/git-the-nosql-database)

[[\[image: Avatar for Brandon Keepers\]](#) bkeepers](https://speakerdeck.com/bkeepers)

PRO

432

67k

[

Building Applications with DynamoDB

](https://speakerdeck.com/mza/building-applications-with-dynamodb)

[[\[image: Avatar for Matt Wood\]](#) mza](https://speakerdeck.com/mza)

96

7.2k

[

What does AI have to do with Human Rights?

](https://speakerdeck.com/axbom/what-does-ai-have-to-do-with-human-rights)

[[\[image: Avatar for Per Axbom\]](#) axbom](https://speakerdeck.com/axbom)

PRO

1

2.3k

Transcript

-

Weird proxies/2

-

About me - Security researcher at Invicti - Web security

enthusiast / pentester <https://github.com/GrrrDog> <https://twitter.com/antyurin> - Co-organizer of Defcon Russia 7812 <https://t.me/DCG7812>

-

Weird proxies/2 - ZeroNights 2018 - "Reverse proxies & Inconsistency"

- https://github.com/GrrrDog/weird_proxies - Research Collisions - Thanks to contributors

-

Reverse proxy - Front-End - Reverse proxy/Load balancer/Cache proxy/... -

Back-end - Origin/Web-Server/...

-

Front-end Request - Route to back-end - Route to endpoints

- Rewrite path/query - Deny access - Headers modification - ... Response - Cache - Headers modification - Body modification - ...

HTTP/1.1 Request-line: method SP request-target SP HTTP-version CRLF GET /path/

HTTP/1.1 - Request-line Host: target.com Header: value

Server - Receive Request - Parse - Normalize (/path/.. ->

/path/, urldecode) - Apply rules (deny /admin, proxy to /endpoint2/) - Recreate Request (urlencode, initial/norm. path) - Send Request Inconsistency between Front-end and Back-end

Host misrouting Haproxy: - Doesn't support Absolute URI - Forwards

as is GET http://backend.com/q?name=X&type=Y HTTP/1.1 Host: target.com Nginx: - backend.com "rewrites" Host header

Host misrouting GET http://localhost/q?name=X&type=Y HTTP/1.1 Host: target.com Haproxy: - target.com

Nginx: - localhost

Nginx - Accepts raw bytes (0x01-0x20) in path as-is GET

/path/<TAB>HTTP/1.1 HTTP/1.1 Path => /path/<TAB>HTTP/1.1

Nginx - No trailing slash in proxy_pass proxy_pass http://backend -

Forwards the initial path After: GET /path/<TAB>HTTP/1.1 HTTP/1.1

Gunicorn - Reads until 1st whitespace with HTTP/1.1 - Accepts

arbitrary string in HTTP version GET /path/ HTTP/1.1 anything

Path misrouting Nginx + Gunicorn location /public/path { proxy_pass http://backend_gunicorn;

}

-

Path misrouting GET /admin/<TAB>HTTP/1.1/../../public/path HTTP/1.1 Nginx: - After normalization -

/public/path - Forwards - /admin/<TAB>HTTP/1.1/../../public/path Unicorn: - After parsing - /admin/

-

Caddy - urldecodes, but doesn't normalize the path - Bypasses,

misrouting - //admin/ ../admin/ /Admin/ - Support fastcgi - php-fpm - as "back-end" - Idea: path traversal in SCRIPT_FILENAME for php-fpm

-

Caddy @phpFiles path *.php reverse_proxy @phpFiles 192.168.78.111:9000 { trans port fastcgi

{ split .php } }

-

Caddy - Caddy's fastcgi module internally normalizes path - <=2.4.?

- Path traversal vuln - ../../../../any/path/www/index.php HTTP/1.1 -
<https://github.com/caddyserver/caddy/pull/4207> - no cve :(
-

URL/Header manipulation Caddy: route /prefix/* { uri strip_prefix /prefix/ reverse_ proxy

192.168.78.111:9999 } Before - GET /prefix/http://localhost/admin HTTP/1.1 After - GET
http://localhost/admin HTTP/1.1

-

URL/Header manipulation - Nginx \$uri - normalized URI (urldecoded) -

Works for any normalized value location /uri { proxy_pass http://192.168.78.111:9999; proxy_set_header
X-uri \$uri; }

-

URL/Header manipulation - %0d%0a -> \r\n - Request Splitting GET

/uri/%0d%0a%0d%0aGET%20/admin%20HTTP/1.1%0d%0aHost:localhost%0d%0a%0d%0a HTTP/1.1

-

URL/Header manipulation After Nginx, a web server sees 2 requests:

—

—

—

—

1

1

—

normalize path - /public/./admin -> /public/./admin - CVE-2021-27306
<https://sewan.medium.com/cve-2021-27306-access-an-authenticated-route-on-kong-a-pi-gateway->

6ae3d81968a3

-

API gateway - Traefik doesn't normalize path - Caddy doesn't

normalize path - Envoy depends on configuration - CVE-2019-9901 (<1.9.1) - Doesn't normalize path in older versions, by default(?) - Many options to setup normalization - Hard to configure properly

-

Header smuggling API Gateway checks auth and adds header -

e.g x-user: admin CGI* "-" is converted to "_" - Traefik, Caddy, Envoy* proxy them - Caddy proxies to fastcgi

-

Caddy: Underscore To Caddy: GET / HTTP/1.1 x_user: ADMIN After

Caddy* (fastcgi): GET / HTTP/1.1 x-user: anonymous x_user: ADMIN

-

Envoy: Double headers - name: envoy.filters.http.ext_authz typed_config: "@type": type.googleapis.com/envoy.extensions.filters.http.ext_authz.v3.ExtAuthz http_service:

server_uri: uri: ext_authz cluster: ext_authz-http-service timeout: 0.250s authorization_response:
allowed_upstream_headers: patterns: - exact: x-user

-

Envoy: Double headers To Envoy GET / HTTP/1.1 x-user: asdasd

x-user: ADMIN - Tested on 1.14.4 After Envoy GET / HTTP/1.1 x-user: User_from_ext_auth x-user: ADMIN

-

Special symbols Test normalization of header names Traefik(1.7.7) - Accepts

header with a trailing space - Forwards without the trailing space - net/http - Before Go 1.13.1 and Go 1.12.10 (CVE-2019-16276)

-

Special symbols To Traefik GET / HTTP/1.1 x-user : ADMIN

After Traefik GET / HTTP/1.1 x-user: ADMIN x-user: anonymous

-

Web cache poisoning Header smuggling with multiple headers Nginx allows

multiple Host headers - Nginx uses 1st Host - fastcgi_pass or uwsgi_pass gets 2nd Host - App trusts Host header - Cache proxy forwards multiple Host headers (smuggled), 2nd Host header is injection point

-

Web cache poisoning Header smuggling and Range header - Range

header returns part of response body Request: - Range: bytes=33- Response: - Status - 206 - Content-Range: bytes 33-106/107

-

Range header - 206 is allowed to cache, by standard

- Most cache proxies don't cache, by default - Can be configured to cache - Varnish doesn't proxy Range header*

-

Range header sub vcl_fetch { # ... if (beresp.status >=

```
200 && beresp.status < 300) { set beresp.cacheable = true; } # ... }
```

<https://docs.fastly.com/en/guides/http-status-codes-cached-by-default>

-

Range header - Browser treats 206 as 200 - If

1 range, server returns same Content-Type - Browser renders part of response - Attack can control part of response - Back-end must support Range

-

Range header - Send request with smuggled Range header -

Cache proxy forwards it to Back-end - Back-end returns a part of response - Cache proxy caches the part - Victim's browser renders only the part - Attacker can escape context

-

HTTP/2 - Binary protocol - Length for fields - Frames

(Headers, Data) - High-level compatibility with HTTP/1.1 - Pseudo-headers - :method, :scheme, :authority, :path - HTTP/2 -> HTTP/1.1

-

HTTP/2 HTTP/1.1: GET /path/ HTTP/1.1 Host: target.com Header: value HTTP/2:

:method:GET :path:/path/ :authority:target.com :scheme:https header:value

-

Restriction bypass Before :method:GET :path:<SP>/admin/ :authority:target.com : scheme:https Header: value <sp>

- white space After GET<SP><SP>/admin/ HTTP/1.1 Host: target.com Header: value

-

- :authority - host header - absolute uri Collision

-

Host misrouting Before Haproxy :authority:target.com host:localhost After Haproxy GET /

HTTP/1.1 Host:localhost

-

Haproxy - Prepend :scheme to path - If it's not

http or https - Allows any symbols in :scheme - except \x00 \x0a \x0d - v2.4.0

-

Misrouting Before Haproxy :path:/any :scheme:http://localhost/admin? :authority:target.com After Haproxy GET http://localhost/admin?://target.com/any

HTTP/1.1

-

Envoy - Allows spec symbols and \x20 \x09 in :method

- v1.18.3 - The same for Haproxy

-

Misrouting Before Envoy :method:GET /admin? :path:/ After Envoy GET /admin?

/ HTTP/1.1 Nginx: /admin? /

-

CPDoS and HTTP/2 - Cache Poisoning DoS - When we

can poison cache proxy with "broken response" - Usually, when proxy caches 4xx, 5xx resps - Meta symbols in header names - Oversized headers

-

Conclusion - New web-servers - old problems - Lack of

path normalization - Configuration-dependent vulnerabilities - New protocol - new opportunities

-

Next steps - Reading list of related articles/presentations - Results

- Docker images https://github.com/GrrrDog/weird_proxies

-

Thank you Questions

Archived from <https://speakerdeck.com/greendog/2-and-a-bit-of-magic>. Rendered offline from the local Markdown copy.